



Security in Apache Kafka

Mohammad Fozouni (Ph.D.)

MLSECOPS IN ACTION COURSE



Layer	Question it answers	Kafka mechanism	If it's missing
Encryption 	"Can anyone eavesdrop on this traffic?"	TLS (security.protocol=SSL)	Data, travels in plaintext. Anyone on the network path can read it.

Layer	Question it answers	Kafka mechanism	If it's missing
Encryption 	"Can anyone eavesdrop on this traffic?"	TLS (security.protocol=SSL)	Data, travels in plaintext. Anyone on the network path can read it.
Authentication 	"Is this client who it claims to be?"	mTLS ssl.client.auth=required	Traffic is encrypted, but <i>anyone</i> can connect. Encryption without authentication just means you have a private conversation with a stranger

Layer	Question it answers	Kafka mechanism	If it's missing
Encryption 	"Can anyone eavesdrop on this traffic?"	TLS (security.protocol=SSL)	Data, travels in plaintext. Anyone on the network path can read it.
Authentication 	"Is this client who it claims to be?"	mTLS ssl.client.auth=required	Traffic is encrypted, but <i>anyone</i> can connect. Encryption without authentication just means you have a private conversation with a stranger
Authorization 	"Now that I know who you are, what are you allowed to do?"	ACLs StandardAuthorizer	Every authenticated client can do <i>everything</i> (read, write, delete, admin) regardless of who they are

Some Useful Concepts

Certificate Signing Request (CSR)



CSR درخواستی است که کلاینت برای گرفتن گواهی امضا شده به CA می‌فرستد، بدون افشای کلید خصوصی‌اش. بعد از امضا شدن توسط CA، CSR دیگر بلااستفاده است و می‌توان آن را حذف کرد.

Certificate Authority (CA)



یک CA فردی هست که شهادت می‌دهد یا تصدیق می‌کند. در پروداکشن ما عمومن از Let's Encrypt اقدام به اخذ CA می‌کنیم. اما در تسک این جلسه خودمان یک CA می‌سازیم و از آن استفاده می‌کنیم.

Certificates



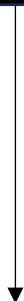
سرتیفیکیت یک کلید عمومی همراه با اطلاعات هویتی هست که توسط فرد دیگری تأیید شده است. سرتیفیکیت می‌گوید «من X هستم. این کلید عمومی من است و Y تصدیق می‌کند».

Public/Private Key Pairs



هر موجودیتی (سرور، ادمین و دانشجو) در این سیستم یک زوج کلید دارد (خصوصی و عمومی). کلید خصوصی را کسی نباید ببیند اما کلید عمومی را می‌توان به همگان داد. هر چیزی که با کلید عمومی رمز بشه تنها با کلید خصوصی قابل رمزگشایی هست.

Certificate Signing Request
(CSR)



CSR درخواستی است که
کلاینت برای گرفتن گواهی
امضاشده به CA می‌فرستد،
بدون افشای کلید
خصوصی‌اش.
بعد از امضا شدن توسط CA،
CSR دیگر بلااستفاده است و
می‌توان آن را حذف کرد.

Certificate Authority (CA)



یک CA فردی هست که
شهادت می‌دهد یا تصدیق
می‌کند. در پروداکشن ما
عموماً از Let's Encrypt اقدام
به اخذ CA می‌کنیم. اما در
تسک این جلسه خودمان یک
CA می‌سازیم و از آن استفاده
می‌کنیم.

Certificates



سرتیفیکیت یک کلید عمومی
همراه با اطلاعات هویتی هست
که توسط فرد دیگری تأیید شده
است. سرتیفیکیت می‌گوید
«من X هستم. این کلید
عمومی من است و Y تصدیق
می‌کند».

Public/Private Key Pairs



هر موجودیتی (سرور، ادمین و
دانشجو) در این سیستم یک زوج
کلید دارد (خصوصی و عمومی).
کلید خصوصی را کسی نباید ببیند
اما کلید عمومی را می‌توان به
همگان داد. هر چیزی که با کلید
عمومی رمز بشه تنها با کلید
خصوصی قابل رمزگشایی هست.

Certificate Authority (CA)



یک CA فردی هست که شهادت می‌دهد یا تصدیق می‌کند. در پروداکشن ما عموماً از Let's Encrypt اقدام به اخذ CA می‌کنیم. اما در تسک این جلسه خودمان یک CA می‌سازیم و از آن استفاده می‌کنیم.

In 2015 and 2019, **Kazakhstan** required citizens to install a government-issued root CA certificate on their devices (framed as "mandatory for internet security"). Once installed, the government held the matching private key. So, it could transparently intercept and decrypt HTTPS traffic by presenting its own valid-looking certificates for those sites (a **MITM** attack, but "legitimate" from the device's point of view since it trusted that root CA).

The Communication Between Client and Broker

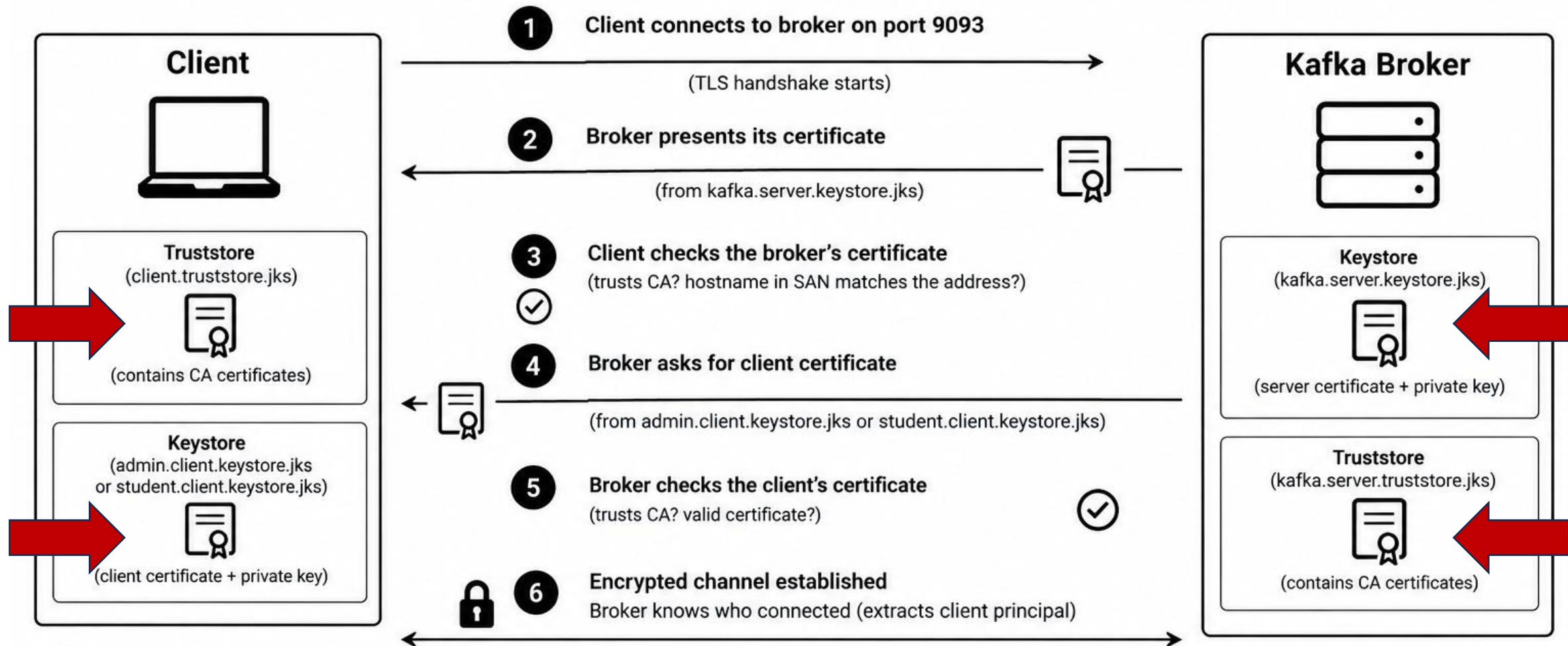
The Communication Between Client and Broker

Keystore = my own identity

It holds your private key and your signed certificate. You present this to the other side during the TLS handshake to prove *who you are*.

Truststore = who I trust

It holds the certificates (usually just the CA's certificate) that you're willing to accept from the other side. It contains no private keys at all. It's purely a list of *these signers are legitimate*.



Authorization:

ACL or Access Control List

a list of permissions associated with a system resource (object or facility)

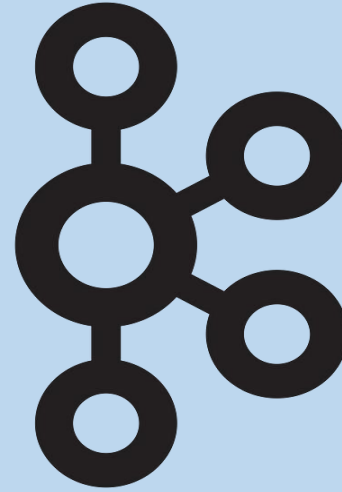
```
kafka-acls.sh --add --allow-principal User:student \  
  --operation Read --operation Describe \  
  --topic public-topic --group '*'
```

Kafka Connect

Kafka Streams

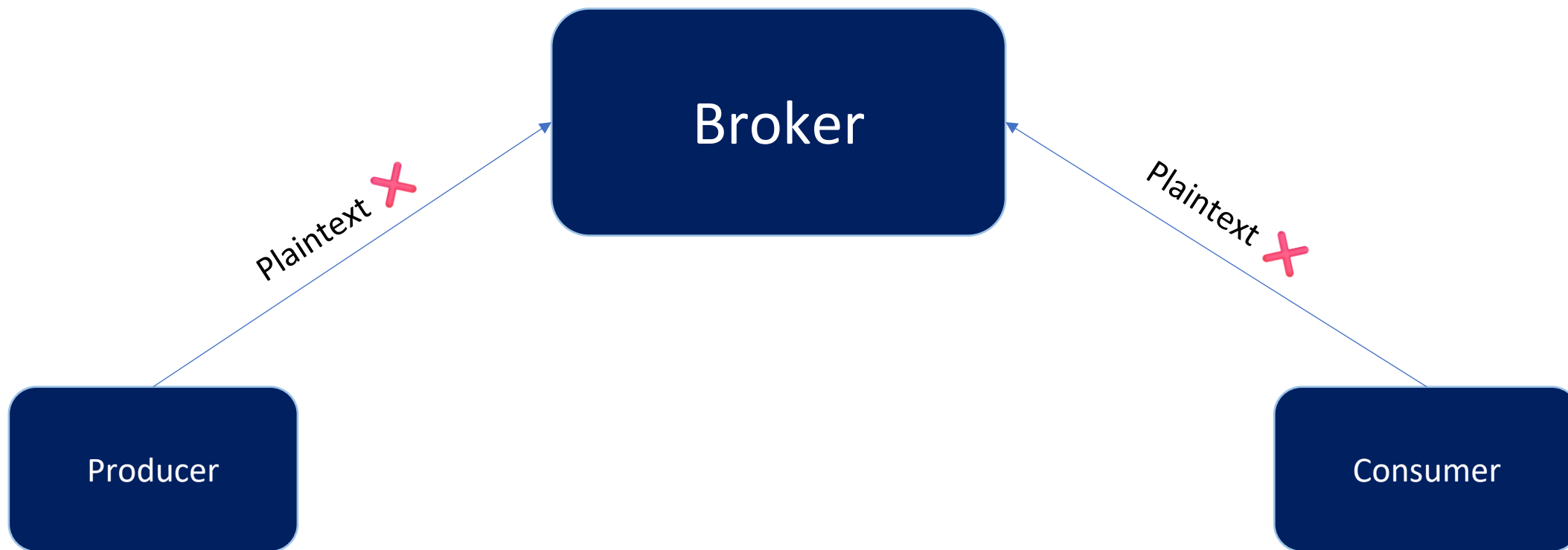
ksqlDB

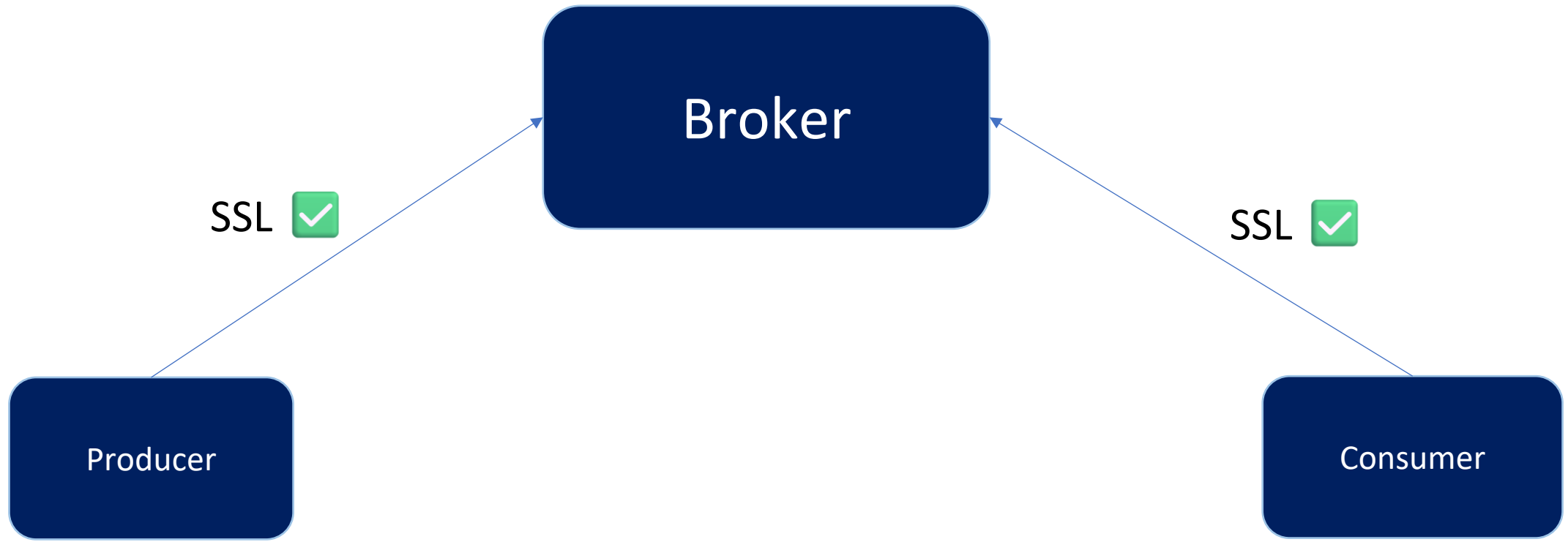
Schema Registry



Storage

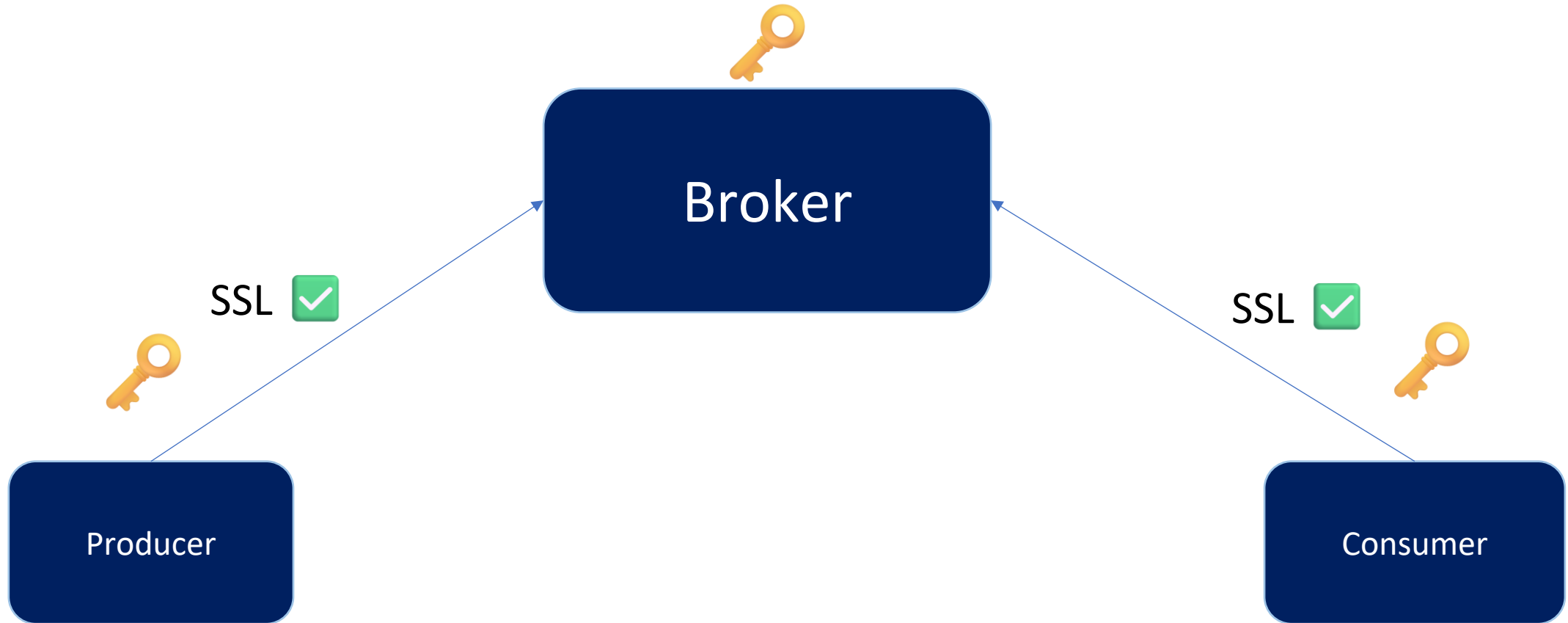
Our Good Friend
Kafka

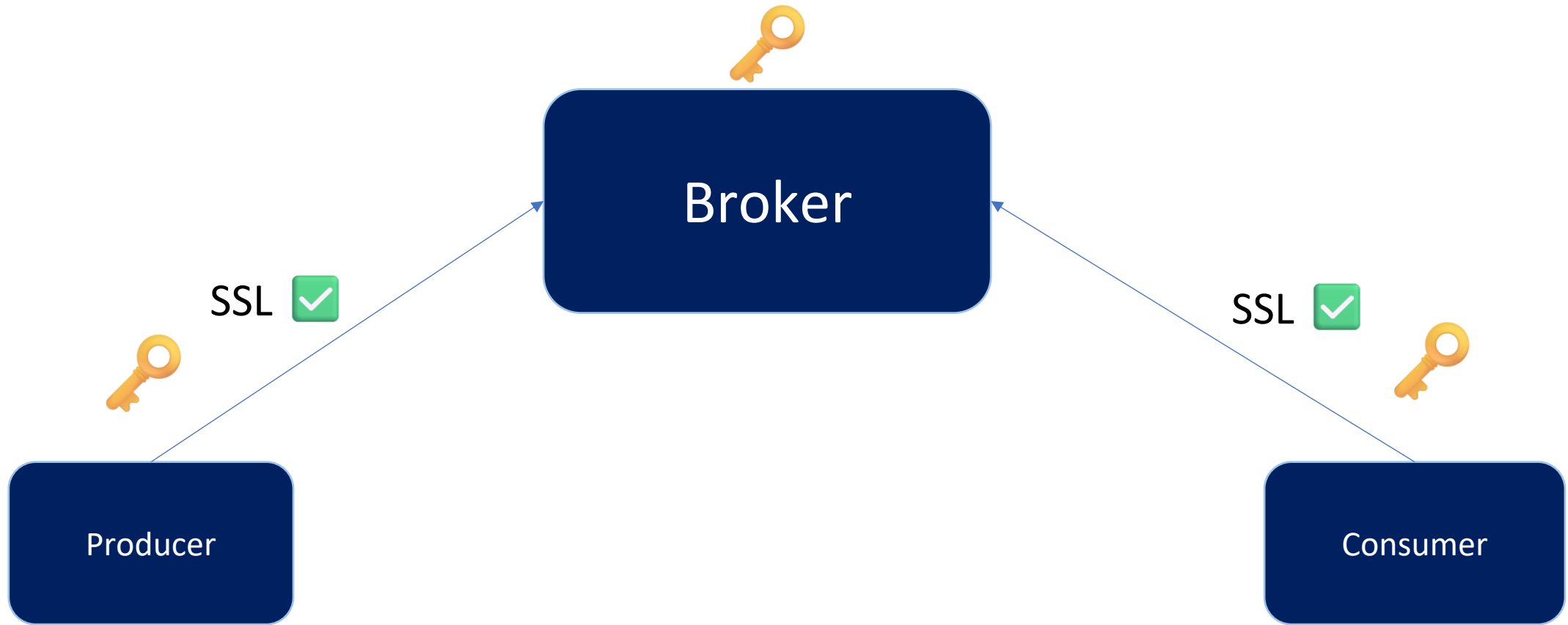




Note that here SSL just create a secure channel for us. Data on the broker is still in plaintext and if someone reach to this server, our data will be GONE 🤖

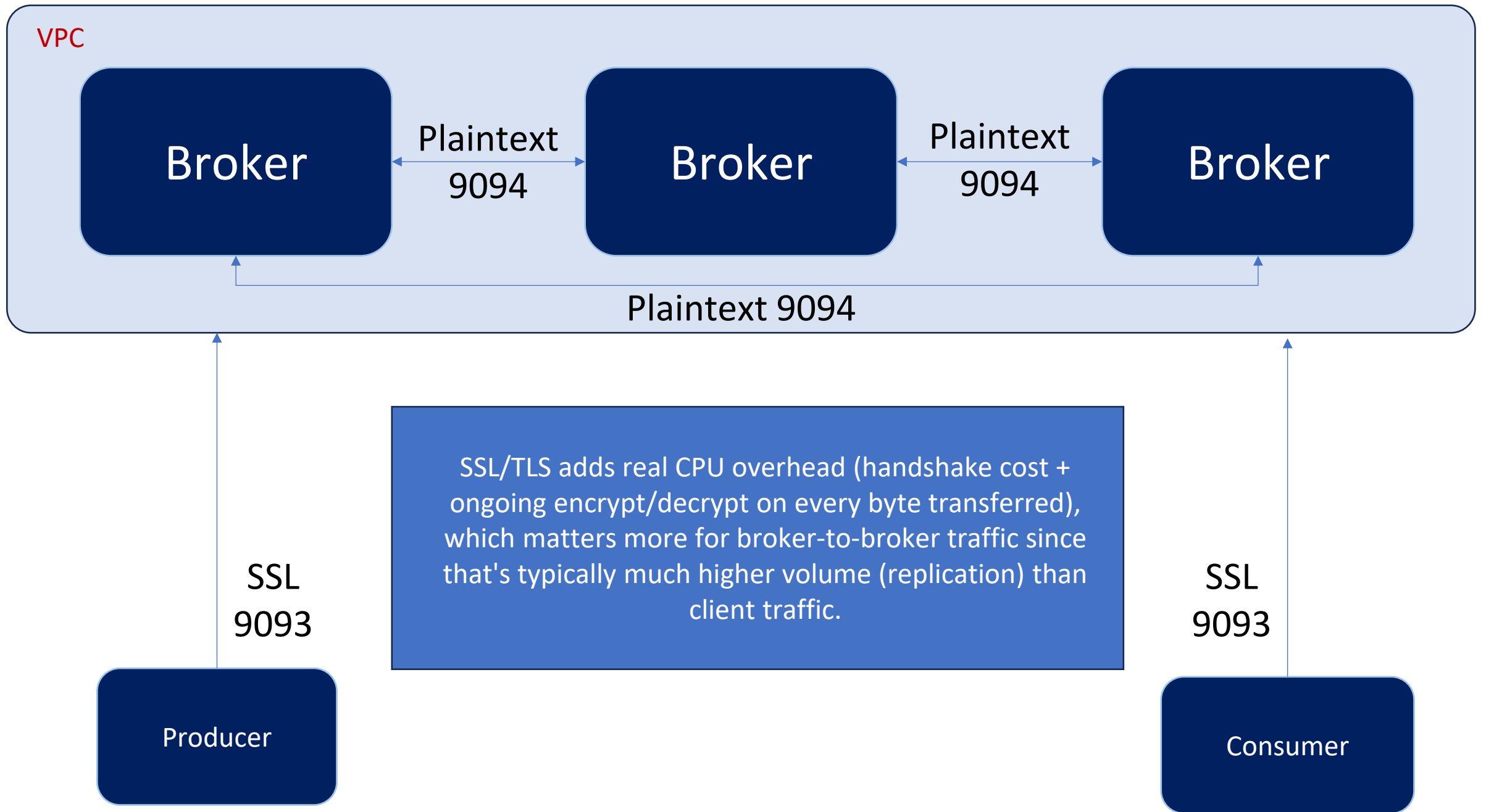
End-to-End Encryption

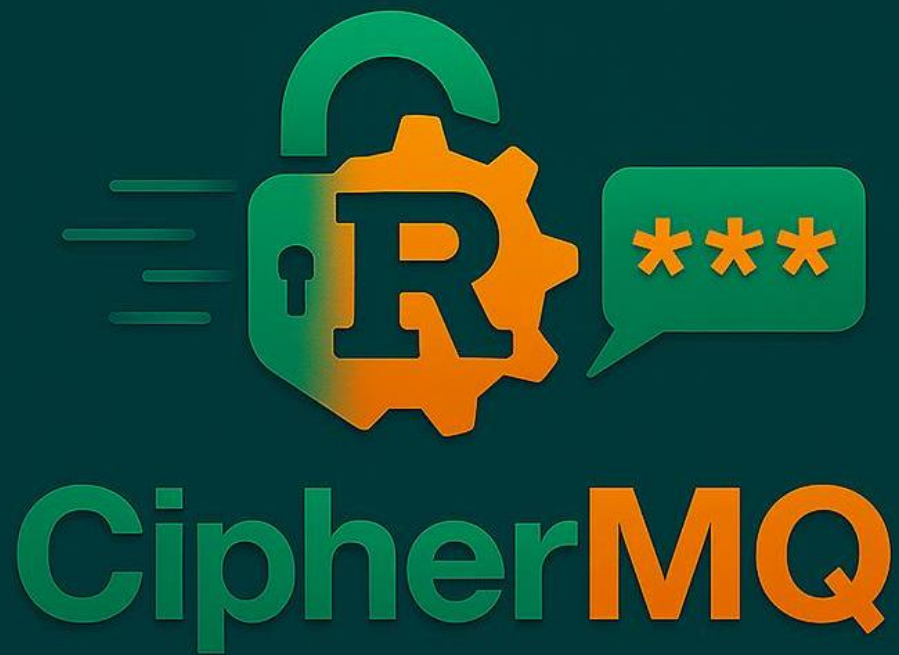




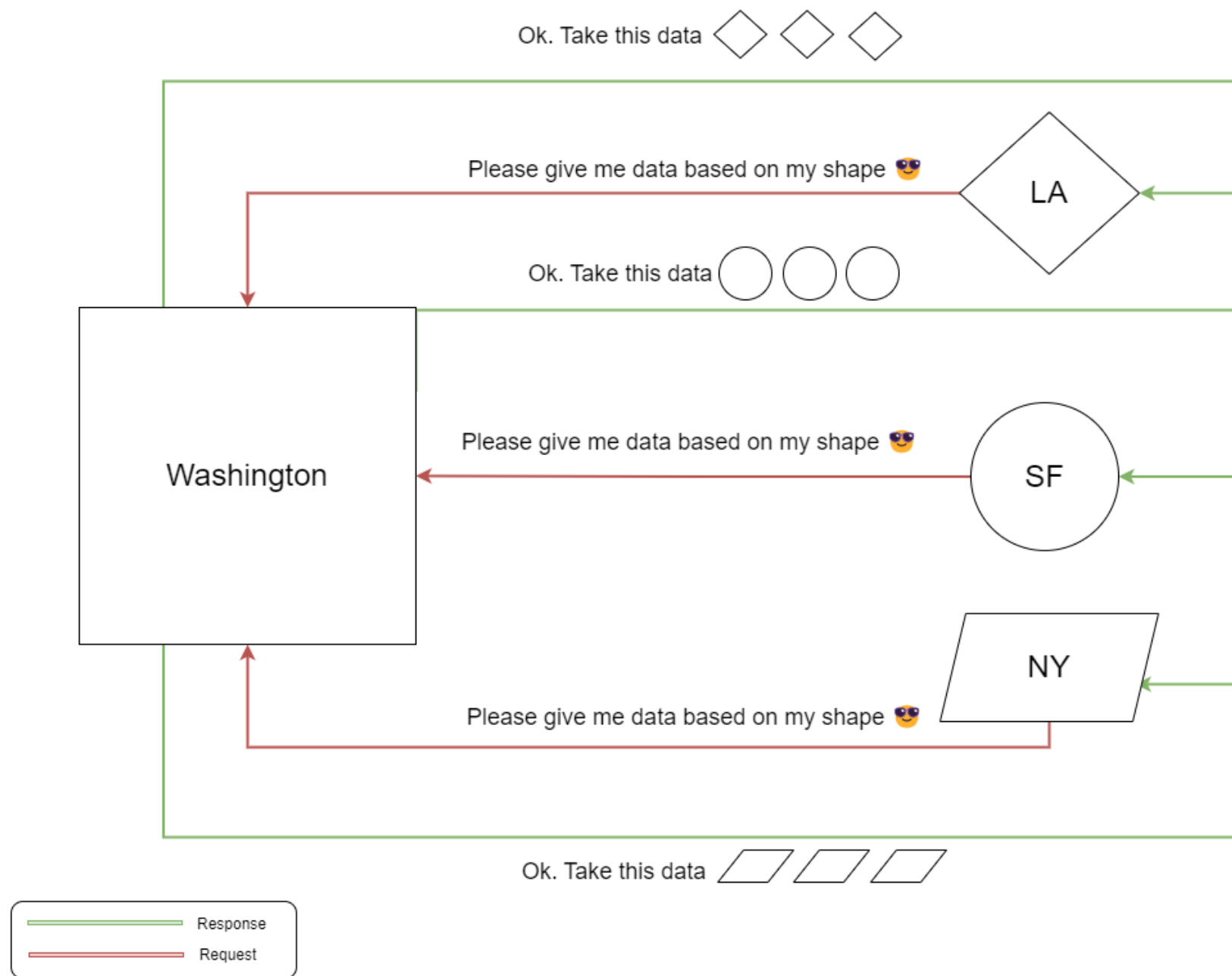
 = Secure our Data

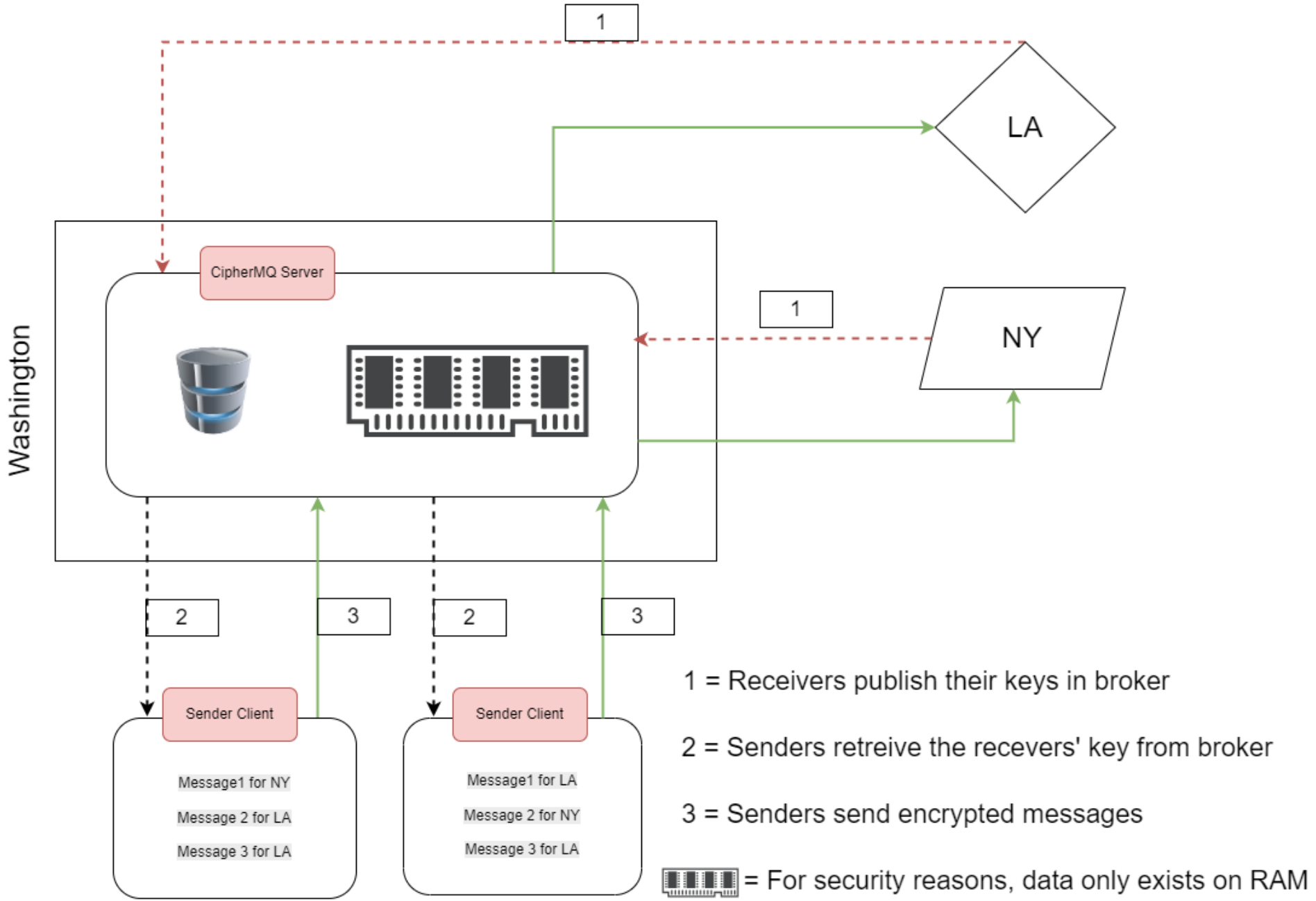
 SSL = Secures the communication channel

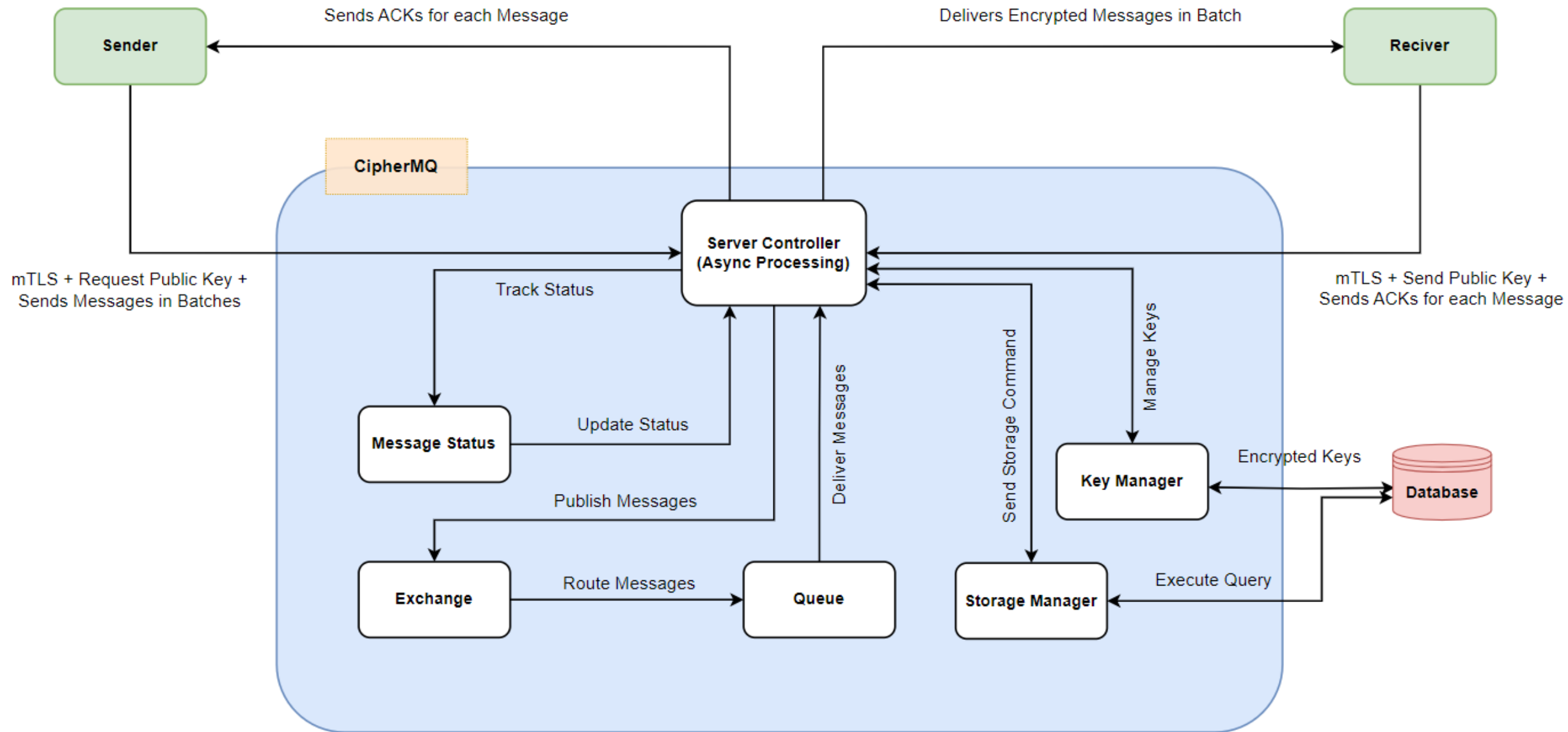


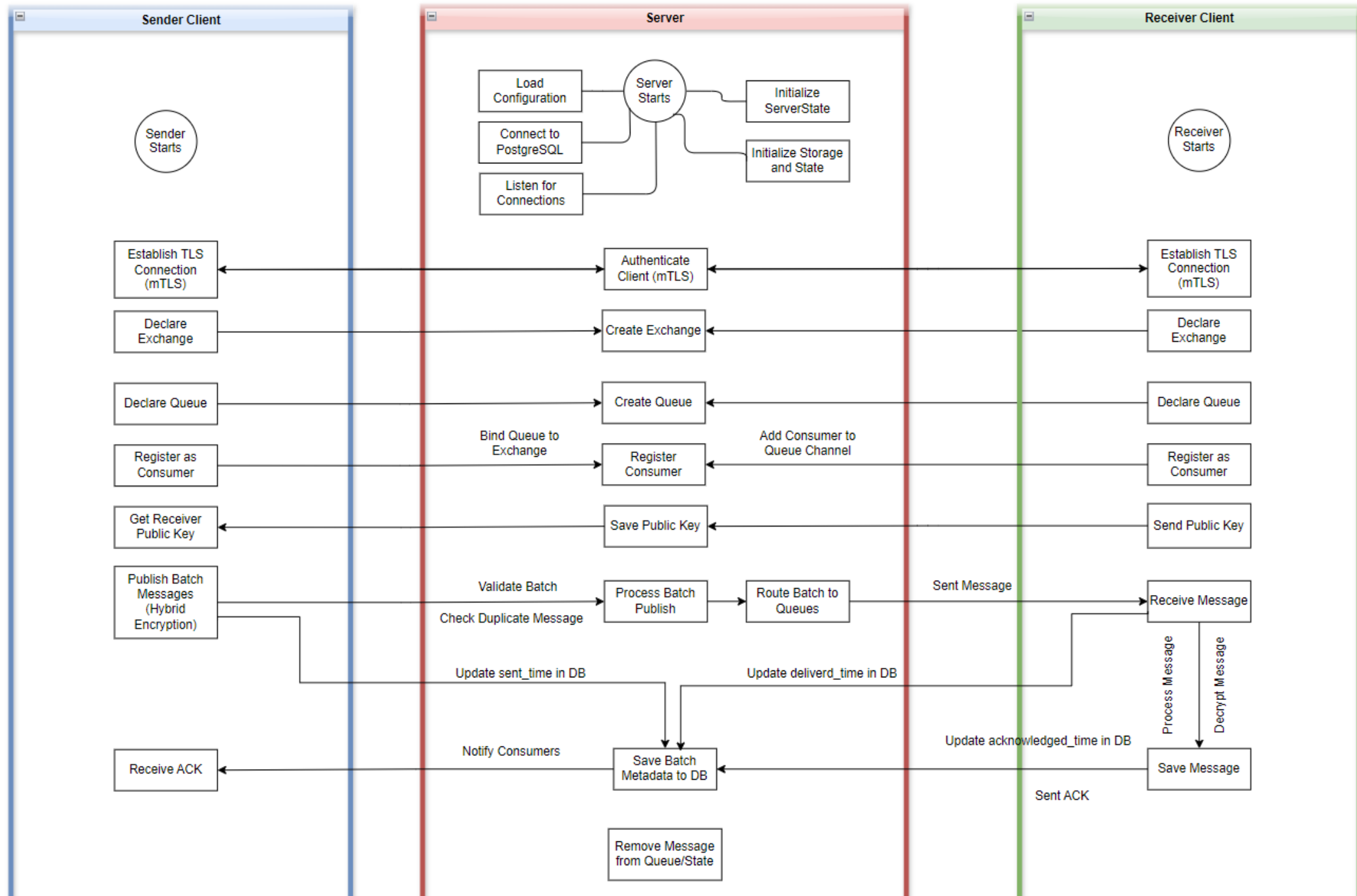


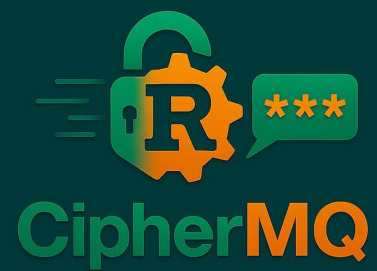
به بهانه‌ی مباحث
امنیتی و صحبت در
باب مسج بروکرها









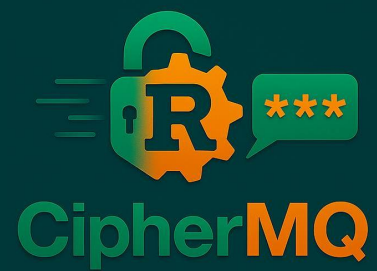


Sender

Broker



Receiver



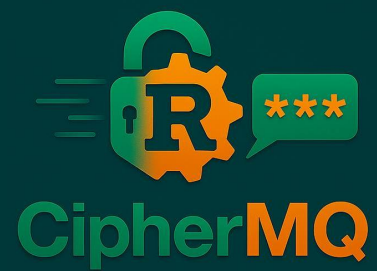
Sender

Broker



Receiver





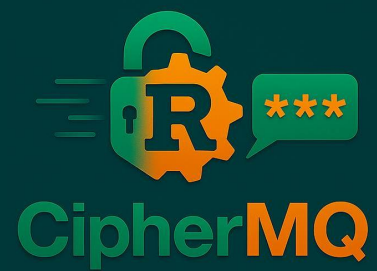
Sender

Broker



Receiver





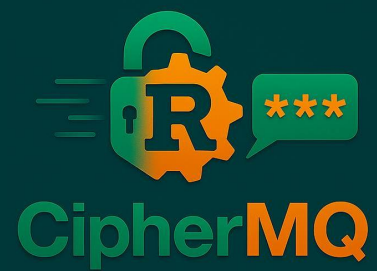
Sender

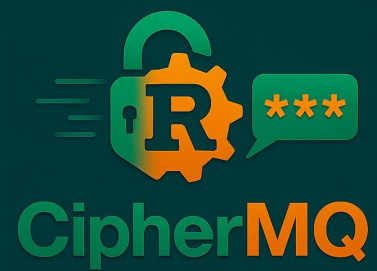
Broker



Receiver







Sender

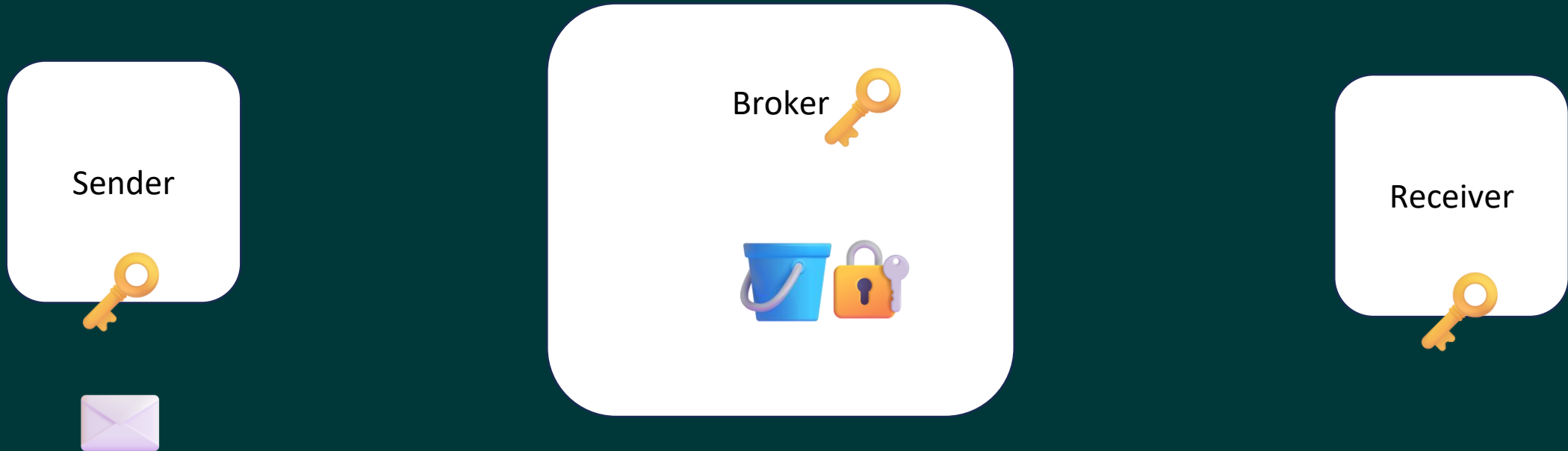
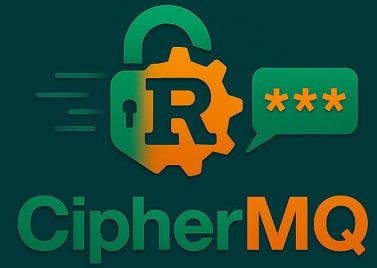


Broker

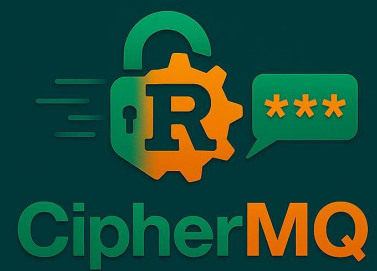


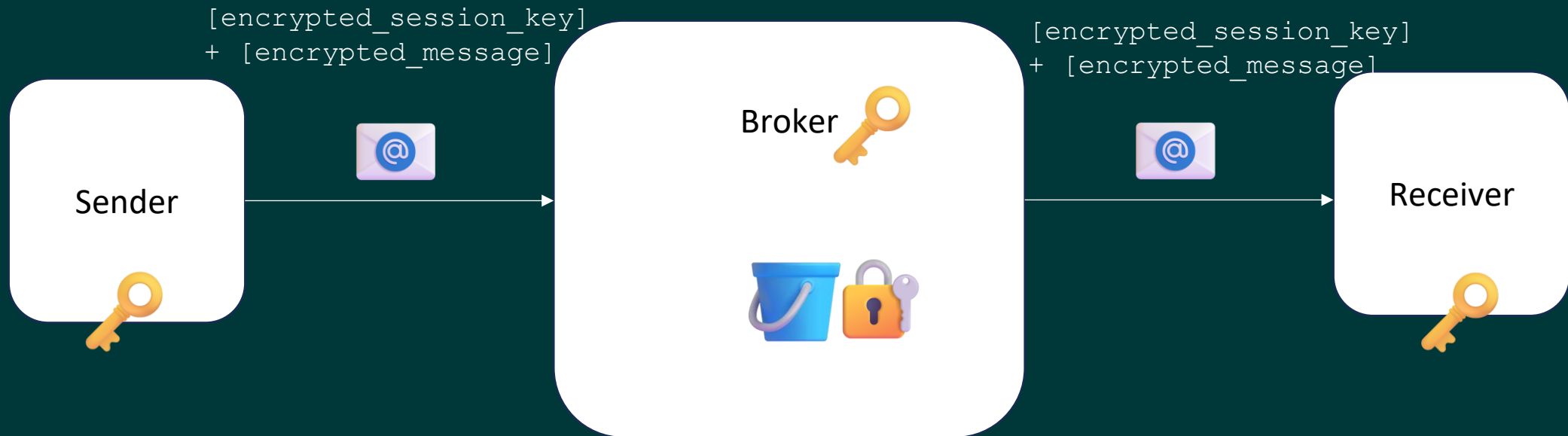
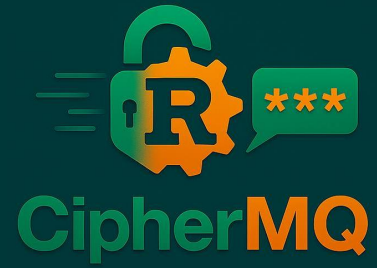
Receiver

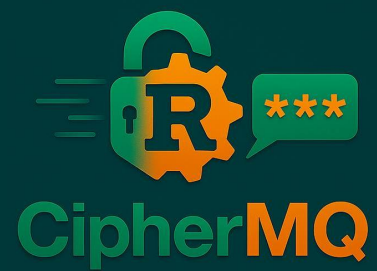




1. Each message encrypted by a session key.
2. Then this session key encrypted by the public key of Receiver.







Sender



Broker



Receiver

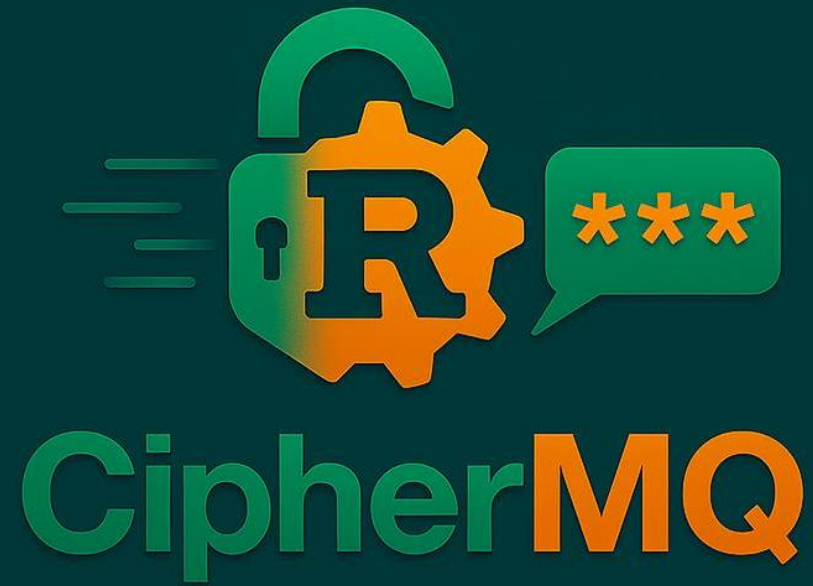


در اوایل طراحی سایفر با راست، ابتدا **سرعت** ما را شگفت زده کرد. اما اندکی گذشت و متوجه شدیم که نمی‌توانیم هم **امنیت** و هم سرعت را به موازات هم پیش ببریم.

در نتیجه تمام تمرکز روی موارد امنیتی گذاشته شد. متوجه شدیم که در دنیا راهکارها تا به امروز تمامن مبتنی بر سرعت بهینه شده بودند.



CipherMQ



The man behind CipherMQ ?????



Ehsan Masoumi · 1st

CipherMQ (Distributed Secure Message System)

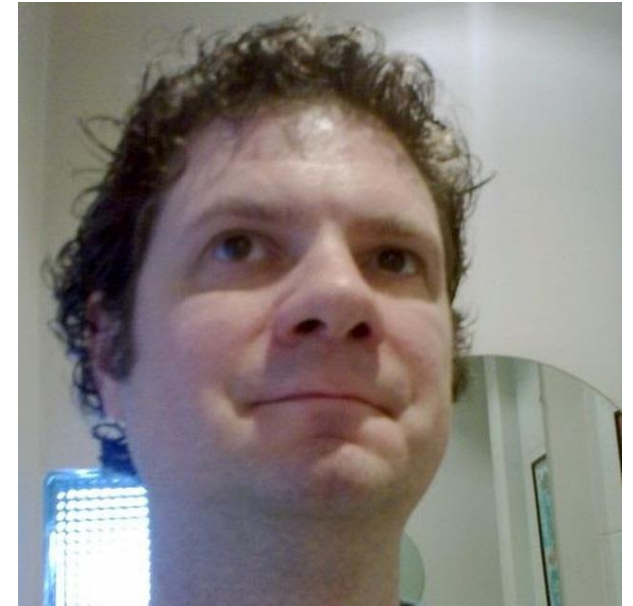
Tehran Province, Iran · [Contact info](#)

[2 connections](#)

 Followed by Ahmadreza, Ali and 32 others you know

 Message

More



Graydon Hoare

Now Let's see a Demo of SECURITY issues in Kafka

